CobiT y los controles de aplicación

EDMUNDO TREVIÑO GELOVER CGEIT, CISM, CISA

AGENDA

1. ANTECEDENTES
2. INTRODUCCIÓN A LOS CONTROLES DE APLICACIÓN
3. OBJETIVOS DE CONTROL DE APLICACIÓN IDENTIFICADOS EN COBIT
4. TIPOS DE CONTROLES DE APLICACIÓN
5. ATRIBUTOS DE LOS CONTROLES
6. MONITOREO DE LA EFECTIVIDAD DE LOS CONTROLES DE APLICACIÓN
7. PROCESO DE ASEGURAMIENTO PARA LOS CONTROLES DE APLICACIÓN
8. GUÍA PARA DEFINIR TAMAÑOS DE MUESTRA PARA PRUEBA DE CONTROLES DE APLICACIÓN

ANTECEDENTES

- Esta charla está dirigida a profesionales de la auditoría interna y externa, incluyendo auditores operacionales y auditores de TI.
- Los controles de aplicación son muchas veces subestimados en los trabajos de auditoría, o se dejan "zonas grises", que nadie atiende, por lo que es necesario conocer más sobre ellos.
- Se deben conocer los atributos de los controles de aplicación y las responsabilidades y roles de las partes involucradas.

INTRODUCCIÓN A LOS CONTROLES DE APLICACIÓN

Los controles de aplicación consisten de actividades manuales y/o automatizadas que aseguran que la información cumple con ciertos criterios, los que COBIT refiere como **requerimientos de negocio para la información**. Estos criterios son:

- Efectividad,
- Eficiencia,
- Confidencialidad,
- Integridad,
- Disponibilidad,
- Cumplimiento y
- Confiabilidad.



INTRODUCCIÓN A LOS CONTROLES DE APLICACIÓN

Los controles de aplicación se establecen para proporcionar una seguridad razonable de que **los objetivos que la gerencia establece sobre las aplicaciones, se alcanzan**. Estos objetivos se articulan típicamente a través de funciones específicas para la solución, la definición de las reglas de negocio para el procesamiento de la información y la definición de procedimientos manuales de soporte. Ejemplo de ello son:

- ✓ Totalidad (Integridad)
- ✓ Exactitud
- ✓ Validez
- ✓ Autorización
- ✓ Segregación de funciones

INTRODUCCIÓN A LOS CONTROLES DE APLICACIÓN

Es necesario asegurarse de que existen suficientes controles para mitigar los riesgos y que están operando con la efectividad necesaria para proveer información confiable.

Durante el ciclo de vida de los sistemas, diversas partes de la organización realizan actividades, responsabilidades y roles asociados con los controles de aplicación.



INTRODUCCIÓN A LOS CONTROLES DE APLICACIÓN
- FASES DEL CICLO DE VIDA

Diseño e Implantación de los Controles de Aplicación

Una parte importante de esta etapa tanto para los sistemas nuevos como para los existentes, es identificar los objetivos de control, evaluar los riesgos y determinar la suficiencia de los controles de aplicación. Si no fue así, se deberán plantear las acciones correctivas necesarias…

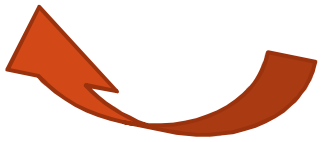
Responsabilidades

Gerencia del Negocio



Que los requerimientos de control en aplicaciones, se establezcan apropiadamente para cumplir con los objetivos de control del negocio.

Gerencia de TI



Que el desarrollo e implantación de los controles de aplicación, se mantengan en concordancia con los requerimientos de negocio definidos.

INTRODUCCIÓN A LOS CONTROLES DE APLICACIÓN
- FASES DEL CICLO DE VIDA

Operación y Mantenimiento de los Controles de Aplicación

El ambiente de proceso de TI en el cual operan los controles de aplicación, necesita ser controlado para asegurar la confiabilidad del proceso de los sistemas. Los cambios en los procesos y en los requerimientos de negocio, deben ser considerados para actualizar y/o mejorar los controles de aplicación.

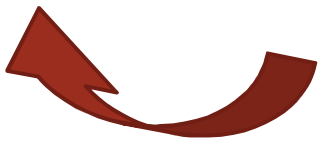
Responsabilidades

Gerencia del Negocio



Del monitoreo de la efectividad operativa de los controles de aplicación y de la identificación y definición de los cambios en los requerimientos de negocio.

Gerencia de TI



De proveer un ambiente de procesamiento confiable y de desarrollar y entregar los cambios basados en los requerimientos de negocio.

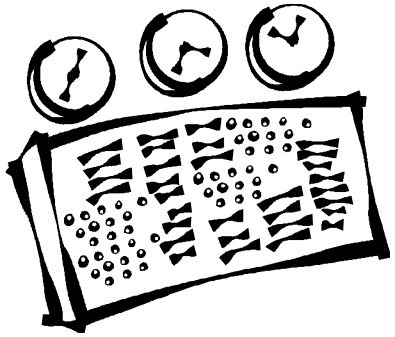
INTRODUCCIÓN A LOS CONTROLES DE APLICACIÓN

- CONTROLES GENERALES

Dependencia de los Controles Generales de TI

Los controles generales de TI son aquellos que tienen que ver con el ambiente de proceso de TI en el cual operan los controles de aplicación. Entre los controles generales están por ejemplo:

- Control de cambios a programas
- Controles de acceso físico
- Controles de acceso lógico
- Controles de continuidad operativa

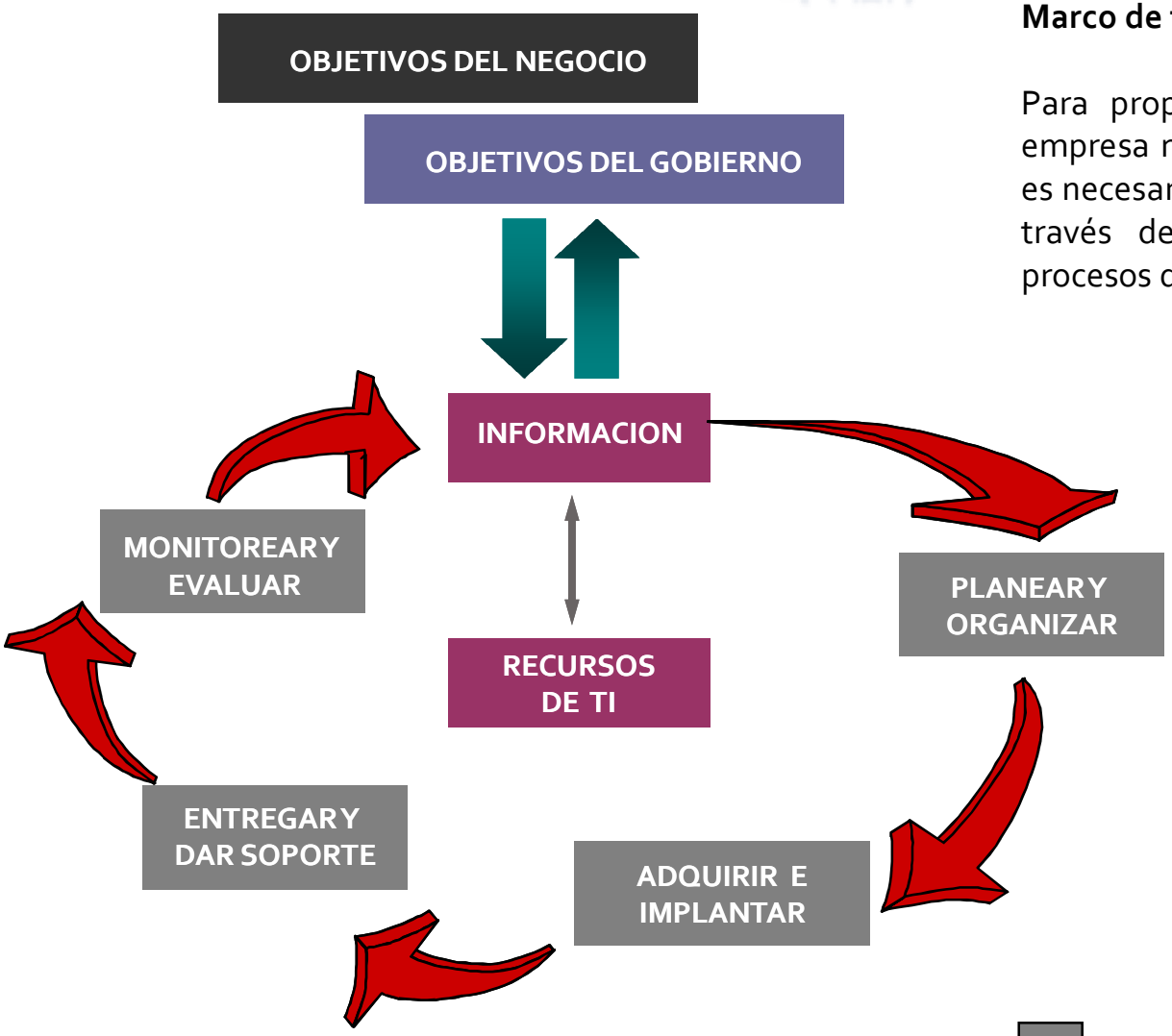


El hecho de que los controles generales sean adecuados, no garantiza que los controles de aplicación serán adecuados.

Pero si los controles generales son deficientes, los controles de aplicación muy probablemente lo serán también.

INTRODUCCIÓN A LOS CONTROLES DE APLICACIÓN

-COBIT



Marco de trabajo general COBIT

Para proporcionar la información que la empresa necesita para lograr sus objetivos, es necesario administrar los recursos de TI a través de un conjunto estructurado de procesos de TI.

= Dominios de COBIT

OBJETIVOS DE CONTROL DE APLICACIÓN IDENTIFICADOS EN COBIT

- **AC1 Preparación y Autorización de Información Fuente.**

  Asegurar que los documentos fuente están preparados por personal autorizado y calificado siguiendo los procedimientos establecidos, teniendo en cuenta una adecuada segregación de funciones respecto al origen y aprobación de estos documentos. Detectar errores e irregularidades para que sean informados y corregidos.

- **AC2 Recolección y Entrada de Información Fuente.**

  Establecer que la entrada de datos se realice en forma oportuna por personal calificado y autorizado. Las correcciones y reenvíos de los datos que fueron erróneamente ingresados se deben realizar, sin comprometer los niveles de autorización de las transacciones originales. En donde sea apropiado para la reconstrucción, retener los documentos fuente originales durante el tiempo necesario.

OBJETIVOS DE CONTROL DE APLICACIÓN IDENTIFICADOS EN COBIT

- **AC3 Chequeos de Exactitud, Integridad y Autenticidad**

  Asegurar que las transacciones son exactas, completas y válidas. Validar los datos ingresados, y editar o devolver para corregir, tan cerca del punto de origen como sea posible.

- **AC4 Integridad y Validez del Procesamiento**

  Mantener la integridad y validación de los datos a través del ciclo de procesamiento. Detectar transacciones erróneas y que no interrumpan el procesamiento de transacciones validas.

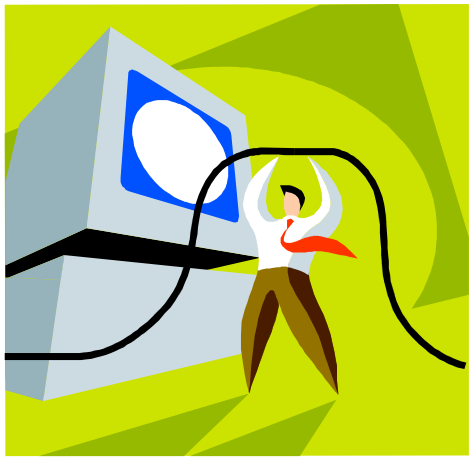
- **AC5 Revisión de Salidas, Reconciliación y Manejo de Errores**

  Establecer procedimientos y responsabilidades asociadas para asegurar que la salida se maneja de una forma autorizada, entregada al destinatario apropiado, y protegida durante la transmisión; que se verifica, detecta y corrige la exactitud de la salida; y que se usa la información proporcionada en la salida.

OBJETIVOS DE CONTROL DE APLICACIÓN IDENTIFICADOS EN COBIT

- **AC6 Autenticación e Integridad de Transacciones**

  Antes de pasar datos de la transacción entre aplicaciones internas y funciones de negocio/operativas (dentro o fuera de la empresa), verificar el apropiado direccionamiento, autenticidad del origen e integridad del contenido. Mantener la autenticidad y la integridad durante la transmisión o el transporte.



OBJETIVOS DE CONTROL DE APLICACIÓN Y LOS CRITERIOS DE INFORMACIÓN

Application Control Objectives	Information Criteria: Effectiveness	Efficiency	Confidentiality	Integrity	Availability	Compliance	Reliability
AC1 Source Data Preparation and Authorisation	S	P	S	P		S	
AC2 Source Data Collection and Entry	S	S	S	P		S	
AC3 Accuracy, Completeness and Authenticity Checks	S	P	S	P	S	P	P
AC4 Processing Integrity and Validity			P	P	P	P	P
AC5 Output Review, Reconciliation and Error Handling	P	S	P	P	P	P	P
AC6 Transaction Authentication and Integrity		S	P	P		P	

P = Primary; S = Secondary

Fuente: COBIT and APLICATION CONTROLS: A Management Guide

© 2009 ISACA. All rights reserved

TIPOS DE CONTROLES DE APLICACIÓN

- **Controles de aplicación Manuales.**

  Son controles ejecutados sin la asistencia de sistemas automatizados. Ejemplos:

  - Autorizaciones escritas, como firmas en cheques.
  - Reconciliación de órdenes de compra con los formatos de recepción de mercancías.

- **Controles de aplicación Automatizados.**

  Son controles que han sido programados e integrados en una aplicación computacional.

  Ejemplos:

  - Validaciones de edición y contenido de datos de entrada.
  - Dígitos verificadores para validar números de cuenta.

TIPOS DE CONTROLES DE APLICACIÓN

- **Controles de aplicación Híbridos o dependientes de controles de aplicación automatizados.**

  Son controles que consisten de una combinación de actividades manuales y automatizadas.

  Ejemplo:

  - El proceso de llenado de órdenes de embarque puede incluir un control donde el gerente de embarques revisa un reporte de órdenes no embarcadas.

  Para que este control sea efectivo, la actividad automatizada (generación de un reporte completo y seguro de órdenes no embarcadas) así como la actividad manual (revisión y seguimiento por el gerente), son necesarias para que el control sea efectivo.

  Se debe tener cuidado de no considerar los controles híbridos como controles manuales, pues entonces se puede dejar de lado el aseguramiento de la actividad automatizada.

TIPOS DE CONTROLES DE APLICACIÓN

- **Controles de aplicación Configurables.**

  Son controles automatizados que están basados y por lo tanto son dependientes de la configuración de parámetros dentro de la aplicación.

  Ejemplo:

  - Un control en un sistema de compras automatizado, que permite órdenes hasta un límite de autorización, es dependiente de controles sobre los cambios en los límites preconfigurados de autorización.

  En muchos casos, las aplicaciones comerciales o desarrolladas en casa, son altamente dependientes de la configuración de varias tablas de parámetros .

  Es apropiado considerar el diseño del control sobre las tablas como un elemento separado.

ATRIBUTOS DE LOS CONTROLES

- **Frecuencia del Control.**

  Esta característica se relaciona con que tan frecuentemente es aplicado un control (diaria, semanal, mensual, etc.). Esta necesita ser considerada en el contexto de riesgo.

  Tal vez la frecuencia anual de revisión de la nómina no sea suficiente y por otro lado, una revisión de un balance diario, pueda dar lugar a errores y debe hacerse mensualmente.

- **Proximidad del Control al evento de Riesgo.**

  Esta característica considera dónde , dentro del proceso, se aplica la actividad de control. Si la entrada de datos es una preocupación, entonces la actividad de control debe ser mas efectiva entre más cerca esté de dicho evento dentro del proceso.

ATRIBUTOS DE LOS CONTROLES

- **Ejecución de la actividad de Control.**

  Saber **quién** ejecuta el control es una característica relevante, sobre todo en los controles manuales , ya que ello implica roles y responsabilidades por las decisiones y aprobaciones relacionadas con el control.

  Esta característica considera si las responsabilidades han sido apropiadamente segregadas de otras responsabilidades incompatibles.



MONITOREO DE LA EFECTIVIDAD DE LOS CONTROLES DE APLICACIÓN

- **El control como subconjunto de actividades de un proceso.**

  Las actividades de control sobre las aplicaciones, son un subconjunto de todas las actividades de un proceso de negocio y deben ser incluidas en el monitoreo de la gerencia sobre todo el proceso.

- **Necesidad del monitoreo.**

  Los controles de aplicaciones requieren ser monitoreadas para asegurar su efectividad.

- **Responsabilidad del monitoreo de la efectividad.**

  Dado que las actividades relacionadas con los controles de aplicación son parte de un proceso de negocio, **los responsables de este proceso son también responsables de monitorear la efectividad de la operación de los controles de aplicación.**

MONITOREO DE LA EFECTIVIDAD DE LOS CONTROLES DE APLICACIÓN

- **Monitoreo de la efectividad de los controles de aplicación cuya ejecución es delegada a terceros.**

  La responsabilidad por la ejecución puede ser delegada a terceros, pero **la gerencia sigue siendo responsable de la efectividad de la operación de los controles.**

  La gerencia debe hacer evaluaciones periódicas de la efectividad de los controles de aplicación, llevando a cabo autoevaluaciones, revisiones de auditoría interna y revisiones de terceros.

  En todo caso, **ya sea que los controles de aplicación sean ejecutados por terceros o internos, la gerencia debe identificar si estos son apropiados y se están ejecutando adecuadamente.** Debe revisar los informes de incidentes y problemas y dar un seguimiento a las acciones remédiales que sean necesarias.

TABLA RACI

Actividades		Stakeholders									
		Ejecutivo de Negocio	Dueños de Procesos de Negocio	Analistas de Negocio	Usuarios Finales	Administradores de Proyecto	Operadores de Sistemas	Programadores de Sistemas	Especialistas de Riesgo y Control	Auditores Internos y Externos
Opera la Solución Automatizada	Habilita la efectividad y confiabilidad de la operación de la solución automatizada.	I	C/I		I		R/A			C/I
Monitorea la Efectividad de los Controles de Aplicación	Supervisa el desempeño de las actividades clave de control manual.		A/R		R					C
	Supervisa la identificación, priorización, escalación y resolución de las excepciones de control, fallas y errores de procesamiento.	I	A/R		R					C
	Monitorea la efectividad continua de los controles de aplicación en los servicios de terceros.		A/R							
	Monitorea las métricas de proceso y los indicadores clave de desempeño.	I	A/R		R					C
	Desarrolla evaluaciones periodicas de la efectividad de control.	I	A/R		R					C

R- Responsible, **A**- Accountable, **C**- Consulted, **I**- Informed

TABLA RACI

	Actividades	Stakeholders								
		Ejecutivo de Negocio	Dueños de Procesos de Negocio	Analistas de Negocio	Usuarios Finales	Administradores de Proyecto	Operadores de Sistemas	Programadores de Sistemas	Especialistas de Riesgo y Control	Auditores Internos y Externos
Administra los Cambios a los Controles de Aplicación	Identifica necesidades de cambio en los procesos de negocio y en las soluciones automatizadas subyacentesy y define los requerimientos del negocio.	C	A/R	R	C	I				I
	Evalua el impacto de los cambios en los controles de aplicación y define los requerimientos de control necesarios y sus cambios.		A/R	R	C	I		C	C	C
	Diseña, construye, prueba e implementa los cambios a las soluciones automatizadas, incluyendo los controles de aplicación automatizados, con base en los requerimientos de negocio definidos.	Ver CobIT 4.1 Procesos AI6 y AI7								
	Diseña, construye, prueba e implementa los cambios a los procesos de negocio incluyendo los procedimientos de controles manuales de la aplicación, con base en los requerimientos de negocio definidos.	C	A/R	R	R	R			C	C
	Administra los cambios a las tablas de información del negocio, datos maestros, y tablas de configuración de usuario administrador.		A/R		R					C
	Administra los cambios a las tablas de información del negocio y tablas de configuración del administrador de TI.	C	A				R			C

R- Responsible, **A**- Accountable, **C**- Consulted, **I**- Informed

PROCESO DE ASEGURAMIENTO PARA LOS CONTROLES DE APLICACIÓN

- El proceso de aseguramiento para los controles de aplicación contempla 6 Etapas.



Fuente: COBIT and APLICATION CONTROLS: A Management Guide

© 2009 ISACA. All rights reserved

PROCESO DE ASEGURAMIENTO PARA LOS CONTROLES DE APLICACIÓN

- **Etapa 1: Entendimiento**

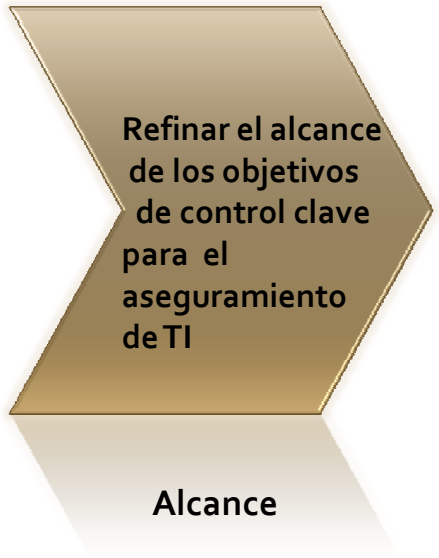


En esta etapa es necesario identificar:

- Las aplicaciones dentro del alcance, incluyendo aplicaciones dependientes e interfases.
- Entradas, salidas y almacenamiento de datos.
- Los tipos y fuentes de información procesada por la aplicación.
- La naturaleza del procesamiento que ejecuta la aplicación: Cálculos, sumarizaciones, transformaciones.
- Tipos y destinos de la información de salida.
- Importancia de la información para el proceso de negocio.

PROCESO DE ASEGURAMIENTO PARA LOS CONTROLES DE APLICACIÓN

- **Etapa 2: Alcance**



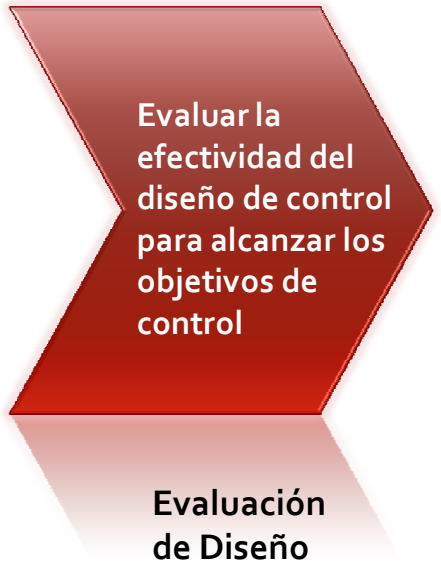
Esta etapa consiste principalmente de:

- Evaluar las amenazas potenciales que puedan afectar los criterios de información relevante y los riesgos asociados.

- Identificar los objetivos de control de la aplicación relevantes para las amenazas y riesgos identificados y necesarios para proveer una garantía de que se cumplen los requerimientos de las partes de negocio interesadas.

PROCESO DE ASEGURAMIENTO PARA LOS CONTROLES DE APLICACIÓN

- **Etapa 3: Evaluación de Diseño**



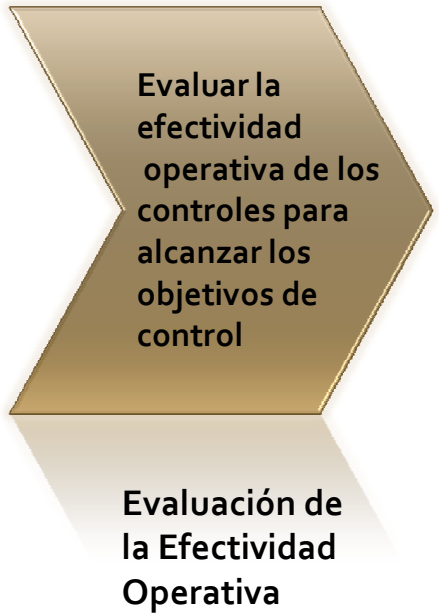
En esta etapa se identifican:

- Las actividades de control que han sido implementadas para lograr los objetivos de control.

- Para llegar a conclusiones se consideran los tipos y atributos de control:
  - ✓ Tipo: Automatizado vs. Manual vs. Híbrido vs. Configurable.
  - ✓ Naturaleza: Preventivo vs. Detectivo
  - ✓ Frecuencia
  - ✓ Proximidad del control al evento de riesgo
  - ✓ Quién ejecuta el control.

PROCESO DE ASEGURAMIENTO PARA LOS CONTROLES DE APLICACIÓN

- **Etapa 4: Evaluación de la Efectividad Operativa**



En esta etapa:

- Se obtiene evidencia de que los controles están operando de acuerdo a lo esperado.
- Se hacen pruebas de los controles.
- Cuatro técnicas de prueba usadas son:
  - ✓ Cuestionar y confirmar
  - ✓ Inspeccionar
  - ✓ Observar
  - ✓ Re-ejecutar
- Es común utilizar herramientas CAAT (Computer Assisted Audit Techinques)

PROCESO DE ASEGURAMIENTO PARA LOS CONTROLES DE APLICACIÓN

- **Etapa 5: Documentación de Debilidades**



El objetivo de esta etapa es:

- Realizar el análisis necesario para lograr un entendimiento de las debilidades de control y las amenazas resultantes, vulnerabilidades e impactos.

- Entre las actividades en esta etapa están:
  - ✓ Documentar los costos incurridos
  - ✓ Identificar consecuencias de no cumplir con requerimientos regulatorios o contractuales
  - ✓ Medir y documentar el costo de los re-procesos.
  - ✓ Comunicar las debilidades encontradas y cuál es la posición de la empresa para enfrentarlas.

PROCESO DE ASEGURAMIENTO PARA LOS CONTROLES DE APLICACIÓN

- **Etapa 6: Conclusiones y Recomendaciones**



En esta etapa el auditor debe llegar a una conclusión acerca de:

- Si hay o no suficiente evidencia de que los controles de aplicación satisfacen los criterios y requerimientos del negocio.
- Si los controles han sido diseñados adecuadamente y están operando correctamente.
- El auditor hará recomendaciones de carácter general.

GUÍA PARA DEFINIR TAMAÑOS DE MUESTRA PARA PRUEBA DE CONTROLES DE APLICACIÓN

- En muchas de las pruebas, el auditor deberá seleccionar una muestra de los eventos de ejecución del control.



- Para determinar el tamaño de la muestra el auditor considerará:
  - El nivel de confianza deseado
  - El rango tolerable de desviación de los controles probados
  - La probabilidad de desviaciones
  - El riesgo aceptable de evaluación de control

GUÍA PARA DEFINIR TAMAÑOS DE MUESTRA PARA PRUEBA DE CONTROLES DE APLICACIÓN

- Aunque hay muchos factores para determinar el tamaño de la muestra, la siguiente tabla muestra los mínimos comúnmente usados:

Figure 16—Guidance for Sample Size Selection		
Nature of Control	**Frequency of Performance**	**Minimum Sample Size**
Manual	Many times per day	25
Manual	Daily	25
Manual	Weekly	5
Manual	Monthly	2
Manual	Quarterly	2
Manual	Annually	1
Automated	Test one application of each programmed control activity (assumes IT general controls are effective).	
IT General Controls	Follow the guidance above for manual and programmed aspects of IT general controls.	

Fuente: COBIT and APLICATION CONTROLS: A Management Guide

© 2009 ISACA. All rights reserved

CONCLUSIONES

- Los controles de aplicación son muy importantes para lograr los objetivos de control del negocio.
- Los controles generales de TI impactan directamente a los controles de aplicación.
- El monitoreo de la efectividad de los controles de aplicación es responsabilidad de la gerencia del negocio.
- Control de aplicación no es sinónimo de control automatizado, pues hay también controles manuales e híbridos.
- La auditoría de los controles de aplicación involucra a los auditores operacionales y a los auditores de TI, debiendo definirse las fronteras de responsabilidad entre ellos.

GRACIAS !!!

Edmundo Treviño Gelover, CGEIT, CISM, CISA, ITIL Cert.
etrevino@alintec.net
www.alintec.net

Alintec
IT Governance Consultants

Alintec México
Tel. +52 (81) 8357-1000